# VULNERA

Gestão de análises de segurança

# Relatório DAST

http://10.87.169.107:5173/

**EMPRESA**
10.87.169.107

**APLICAÇÃO**
Execução real — OWASP ZAP

**GERADO EM**
09/10/2026 às 10:02

Perfil desta execução não registrado. Consulte o relatório HTML original. Solicitado por Vulnera Admin · Duração: 21s.

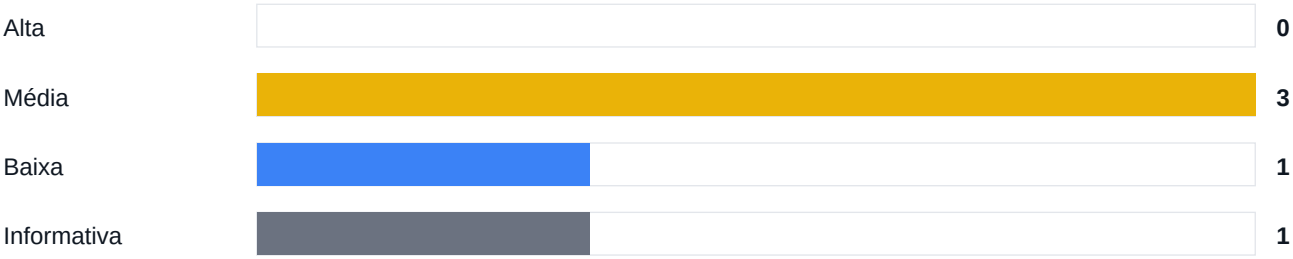
Documento confidencial — uso restrito às partes envolvidas na análise.

## Sumário executivo

O scan contra http://10.87.169.107:5173/ identificou 5 alertas. Cada um está detalhado, por ordem de severidade, na seção seguinte deste documento.

| 5 | 0 | 3 | 1 |
|---|---|---|---|
| Total de achados | Alto | Médio | Baixo |

## Distribuição por risco




## Findings por severidade

### Média 1. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

**URL**
http://10.87.169.107:5173/

**DESCRIÇÃO**
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

**SOLUÇÃO**
Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

### Média 2. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

**URL**
http://10.87.169.107:5173/

**PARÂMETRO**
x-frame-options

**DESCRIÇÃO**
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

**SOLUÇÃO**
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

---

## Média 3. Sub Resource Integrity Attribute Missing

Confiança: High · CWE-345 · WASC-15

**URL**
http://10.87.169.107:5173/

**DESCRIÇÃO**
The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.

**SOLUÇÃO**
Provide a valid integrity attribute to the tag.

**EVIDÊNCIA**
<link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap" rel="stylesheet" />

---

## Baixa 4. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

**URL**
http://10.87.169.107:5173/

**PARÂMETRO**
x-content-type-options

**DESCRIÇÃO**
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

**SOLUÇÃO**
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a

standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

## Informativa 5. Modern Web Application

Confiança: Medium · CWE--1 · WASC--1

**URL**

http://10.87.169.107:5173/

**DESCRIÇÃO**

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

**SOLUÇÃO**

This is an informational alert and so no changes are required.

**EVIDÊNCIA**

<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>

# Apêndice

### METODOLOGIA

O perfil de descoberta desta execução histórica não foi registrado. Consulte o relatório HTML original e o registro operacional da época; a metodologia atual não é atribuída retroativamente a este scan.

### VERSÃO DO ZAP

Consulte o relatório HTML original do ZAP (botão "Ver relatório do ZAP" na tela do scan), que traz a versão usada nesta execução no próprio cabeçalho.

### ESCOPO

Alvo registrado: http://10.87.169.107:5173/. Os limites históricos devem ser conferidos no registro original.

### TRIAGEM E GESTÃO DE RESULTADOS

O pentester pode registrar a triagem e promover manualmente um achado para vulnerabilidade de um projeto, revisando o vetor CVSS sugerido antes de salvar. A vulnerabilidade entra no fluxo de gestão e remediação do Vulnera. A comparação entre execuções reais do mesmo alvo apresenta achados novos, resolvidos e que continuam abertos.

### LIMITAÇÕES CONHECIDAS

O ZAP não fornece vetor CVSS: o risco do alerta não substitui a avaliação humana. No perfil atual, o spider tradicional não executa JavaScript, portanto rotas de uma SPA que dependem dessa execução podem não ser descobertas. O perfil atual não cobre exploração ativa, envio de formulários ou uma auditoria completa da aplicação. Não há agendamento recorrente nem varredura de múltiplos alvos num único scan.